

UNIDAD 1. FUNDAMENTOS DE LA SEGURIDAD INFORMÁTICA

1. INTRODUCCIÓN

El número de usuarios y profesionales informáticos ha crecido exponencialmente, por lo que es necesario:

- **Asegurar** los sistemas y la información.
- Tener **acceso** a los servicios el mayor tiempo posible, sin interrupciones y con calidad.

Las máquinas son **vulnerables** y nuestra **información** también:

- Las conversaciones y mensajes son personales y privados.
- La información pública en Internet debe estar al alcance de todas las personas.
- Las empresas no deben consentir un ataque a su página web, modificando el contenido y engañando a sus clientes y usuarios.
- Los contratos son privados en gran medida. Nadie externo debe alterarlos.

A pesar de todas las medidas de seguridad, su totalidad **no** es **suficiente** para decir que es completa. Por eso debemos elegir lo que es más importante para su protección:

- **Recursos** → Físicos y lógicos.
- **Información.**
- **Equipo Humano.**

1.1 Equipos

Es fundamental que no se puedan **sustraer**, o al menos, que los datos internos estén **cifrados** y que tengan **contraseñas seguras** y actualizadas. Se debe evitar el uso de equipos no autorizados y aplicar su mantenimiento preventivo.

1.2 Aplicaciones

Los equipos de empresas deben tener las aplicaciones estrictamente necesarias para llevar a cabo el trabajo, evitando instalar aplicaciones extras.

Cuando la empresa adquiere nuevos equipos, el equipo de sistemas debe maquetarlo como sea necesario.

- El equipo debe tener las **licencias** necesarias.
- Intentar homogeneizar el equipamiento para reducir problemas.
- Instalar un antivirus en caso necesario.
- Intentar que el equipo no tenga permisos de admin.

1.3 Datos

Los datos pueden:

- **Desaparecer** → La empresa no pueda funcionar con normalidad.
- Ser **adquirido** por la competencia → La estrategia y el futuro de la empresa están en riesgo.

Para ello se deberá tener los equipos protegidos contra software malicioso, tener un almacenamiento redundante y estar cifrado.

1.4 Comunicaciones

La transferencia de la comunicación también debe estar protegida utilizando canales cifrados, incluso la información transferida.

2. DEFINICIÓN DE SEGURIDAD INFORMÁTICA

Seguridad → Es la cualidad de seguro, estar libre y exento de todo daño, peligro o riesgo.

En la informática, es casi imposible de conseguir, por eso hablamos de fiabilidad.

- **Eugene H. Spafford** → El único sistema que es totalmente seguro es aquel que está apagado y desconectado, guardado en una caja fuerte de titanio, enterrado en cemento, rodeado de gas nervioso y un grupo de guardias armados. Aún así, no apostaría mi vida en ello.
- **National Information Systems Security** → La seguridad informática son las medidas y controles que aseguran la confidencialidad, integridad y disponibilidad de los activos de los sistemas de información, incluyendo hardware, software, firmware y aquella información que almacenan, procesan y comunican.
- **ISO 7498-1984** → Serie de mecanismos que minimizan la vulnerabilidad de bienes y recursos en una organización.

3. OBJETIVOS

Los sistemas informáticos son seguros si cumple el **CIDAN**:

- **Confidencialidad.**
 - Accesible por las entidades autorizadas.
 - EFS / GnuPG.
 - Comunicaciones cifradas en simétrico y asimétrico.
- **Integridad.**
 - Modificadas por las entidades autorizadas.
 - SFC / Rootkit Hunter.
 - Firma digital o hash.
- **Disponibilidad.**
 - Disponibles para las entidades autorizadas.
- **Autenticación.**
 - Verificación del usuario.
 - Login + Password / Certificado Digital.
- **No repudio.**
 - Se comprueba que el autor envió la comunicación (no repudio en origen) y que el receptor la recibió (no repudio en destino).

4. CONCEPTOS

Recursos del sistema → Activos a proteger del sistema de información:

- Hardware y Software.
- Elementos de comunicación.
- Información que se almacena, procesa y distribuye.
- Locales y oficinas.
- Usuarios del sistema.
- Imagen y reputación de la organización.

4.1 Amenaza

Son las acciones que aprovechan una **vulnerabilidad** para comprometer la información.

- **Ataque** → Virus, robo, etc.
- **Sucesos físicos** → Catástrofes naturales.
- **Negligencia** → Mal uso de un usuario o personal.

4.2 Vulnerabilidad

Debilidad de un activo o activos que puede ser explotada por una o más amenazas. Pueden proceder de un error en el diseño, implementación y configuración de hardware y software que hacen posibles a los atacantes penetrar en sus sistemas.

4.3 Incidente de Seguridad

Es la materialización de una amenaza. Sucesos no deseados que pueden implicar daños a la organización y/o personas.

- **Internas** → Personal.
- **Externas** → Proveedores.
- **Deliberados** → Busca perjudicar a la organización o soborno.
- **Involuntarios** → Ocurren de forma accidental o el personal no sigue la Normativa de Seguridad de la Información.

4.4 Impacto

Es la **medición** y **valoración** del daño ocasionados por los incidentes.

4.5 Riesgo

Posibilidad de que se produzca un incidente.

- $\text{Riesgo} = \text{Probabilidad de Amenaza (1 - 4)} * \text{Magnitud de Daño (1 - 4)}$
 - Alto Riesgo → Entre 12 y 16.
 - Riesgo Medio → Entre 8 y 9.
 - Bajo Riesgo → Entre 1 y 6.

4.6 Defensas, Salvaguardas o Medidas de Seguridad.

Es cualquier medio empleado para eliminar o reducir un riesgo.

5. SEGURIDAD FÍSICA Y SEGURIDAD LÓGICA

5.1 Seguridad Física

Consiste en la aplicación de **barreras** y **procedimientos** de control físicos para proteger los elementos físicos de la empresa → Hardware y la Infraestructura.

- **Desastres Naturales** → Se tiene en cuenta para saber dónde colocar la infraestructura.
- **Robos** → Proteger mediante vigilantes, tarjetas de acceso, identificación con login + password, etc.
- **Fallos de Suministro** → Uso de baterías por si falla la corriente (SAI), segunda conexión a internet como backup.
- **Amenazas** ocasionadas por el ser **humano**.

5.2 Seguridad Lógica

Se refiere a las distintas aplicaciones que se ejecutan en cada uno de los equipos → Todo lo que no está permitido debería estar prohibido.

El activo más importante es la **información**.

- Restringir acceso a programas y archivos.
- Confidencialidad → La información transmitida sea recibida por quien la ha solicitado.
- Asegurar que los datos, archivos y programas utilizados son los correctos.
- Integridad → La información recibida es la misma a la transferida.
- Contraseñas y Autenticación en dos factores (2FA).
- Cortafuegos.
- Sistemas de detección de intrusos.
- Antivirus.
- Copias de Seguridad.

6. SEGURIDAD ACTIVA Y SEGURIDAD PASIVA

6.1 Seguridad Activa

Cualquier medida capaz de anular o reducir el riesgo de una amenaza. Se implementan para detectar y responder a amenazas en tiempo real o prevenirlas → **Enfoque activo**.

- **Medidas Preventivas** → Aplicación antes del incidente.
 - Control de acceso lógico, autenticación de usuarios, etc.
- **Medidas Reactivas** → Aplicación durante el incidente.
 - Sistemas de detección y prevención de intrusos, análisis de registros, firewall, antivirus, etc.

6.2 Seguridad Pasiva

Complementan a la seguridad activa y es cualquier medida empleada para **reducir** el **impacto** del incidente → Medidas de corrección post incidente → **Enfoque estático**.

- Cifrado de datos.
- Copias de seguridad.
- Control de acceso físico.
- Sistemas SAI o RAID.

7. CONTROL DE ACCESO LÓGICO

Se refiere a las políticas, mecanismos y tecnologías utilizadas para proteger los recursos de un sistema informático, limitando:

- Quién puede acceder a la información.
- Qué acciones pueden realizar
- Cómo se accede a dichos recursos.

7.1 Niveles de Control de Acceso

- **Usuario** → Permisos y privilegios que tiene un usuario individual para acceder al sistema.
 - Contraseñas, autenticación multifactor o identificación biométrica.
- **Arranque** → Medidas de seguridad en las primeras etapas del inicio del sistema.
 - Contraseñas, modo arranque seguro, deshabilitación de periféricos.

- **Sistemas Operativos** → Permisos de los usuarios y aplicaciones para interactuar con el SO.
 - Permisos de archivos y carpetas, sistemas de autenticación.
- **Aplicación** → Permisos de los usuarios dentro de las aplicaciones.
 - Roles, perfiles y reglas de negocio.
- **Red y Comunicaciones** → Qué usuarios y qué dispositivos pueden acceder a la red.
 - Firewall, ACL, segmentación de redes o las VLAN.
- **Administración** → Privilegios de los administradores del sistema para configurar, modificar y supervisar todos los niveles anteriores.
 - Control de privilegios y registros de auditorías.

7.2 Políticas de Contraseñas

La principal técnica para implementar el control de acceso es mediante la utilización de un **servidor de autenticaciones** → LDAP en Linux o Active Directory en Windows.

Suelen ser un punto crítico de la seguridad y suelen recibir distintos tipos de ataque:

- **Fuerza Bruta** → Se intenta recuperar la contraseña probando todas las combinaciones posibles.
- **Diccionario** → Palabras y variaciones de éstas, con significado y utilizadas.

La protección será por el número de intentos, la longitud mínima y el uso de símbolos.

- Longitud Mínima → Se recomienda entre 8 y 14 caracteres.
- Combinación de caracteres → Letras minúsculas y mayúsculas, números y símbolos especiales.
- No incluir secuencias, palabras conocidas o nombres de usuarios.
- Se debe utilizar varias contraseñas para distintos entornos.
- Modificarla con periodicidad.

7.3 Sistemas Biométricos

Son tecnologías que utilizan las características físicas únicas de una persona para verificar su identidad → Difíciles de replicar, imitar o robar.

- **Características físicas** → Permanecen inalteradas durante la vida.
 - Huella dactilar.
 - Reconocimiento facial, de iris o de voz.
- **Características comportamentales** → Forma de realizar ciertas acciones.
 - Firma.
 - Patrones de escritura.

7.4 Listas de Control de Acceso (ACL)

Herramienta que **define** y **controla** el acceso lógico a los recursos de un sistema → Especifica quién puede acceder a un recurso y qué acciones puede realizar sobre él.

- Común en seguridad de redes, sistemas, bases de datos y otros entornos informáticos.

Política de seguridad basa en ACL → Define reglas específicas que controlar qué usuarios o sistemas tienen permiso para interactuar con determinados recursos.

Elementos de una ACL:

- **Sujeto** → Usuario, grupo, dispositivo, proceso o dirección IP.
- **Recurso** → Archivo, directorio, base de datos, dispositivo o red a la que se quiere acceder.
- **Acciones / Permisos** → Define lo que está permitido o denegado para el sujeto sobre el recurso.

8. INGENIERÍA SOCIAL

Técnica de manipulación que aprovecha el eslabón más débil del sistema, el **humano**, para acceder a la información privada que tiene un valor incommensurable. Es una de las técnicas más usadas por ciberdelinquentes que tienen dos objetivos:

- Alterar o corromper los datos.
- Robar información personal, acceso o dinero.

Estos ciberdelinquentes nos engañan de la siguiente manera:

- **Pretexting** → Crean un escenario o una historia ficticia haciendo que la víctima comparta información → Llamada de estafa.
- **Phishing** → Uso de archivos infectados o falso enlace a una web → Correo electrónico.
- **Sextorsión** → Chantaje del atacante a la víctima, indicando que va a distribuir contenido comprometido a todos sus contactos.
- **Baiting** → El atacante presenta un cebo para que la víctima instale en su equipo un software malicioso para envenenar de manera invisible su sistema y así sustraer información valiosa.
- **Smishing** → Variante del phishing pero a través de SMS o mensajería instantánea.
- **Vishing** → Hacerse pasar por una persona de confianza para obtener la información → Llamada telefónica.
- **Shoulder Surfing** → Robar datos personales en el uso diario de dispositivos personales o profesionales mirando “por encima del hombro”.
- **Quid Pro Quo** → Prometen un beneficio a cambio de información personal usada para robar dinero, datos, etc.
- **Dumpster Diving** → Husmear en la basura de una persona para encontrar información útil.
- **Redes Sociales** → Engaños con cupones de descuentos, juegos, concursos, etc.

Para protegernos de estos delitos, debemos usar el **sentido común** y prestar atención.

9. ANÁLISIS FORENSE

Herramienta esencial para la **investigación** de **incidentes** de seguridad y recuperación de datos. Se centra en la identificación, preservación, análisis y presentación de datos almacenados electrónicamente.

Objetivo → Investigar dichos incidentes que involucre sistemas informáticos → Cómo ocurrió, quién lo llevo a cabo y cómo evitar en el futuro.

9.1 ¿Para qué Sirve?

- Descubrir vulnerabilidades.
- Recuperar datos.
- Recuperar tecnología afectada.
- Mejorar la respuesta a incidentes.
- Prevenir futuros ataques.
- Apoyar procesos legales.

9.2 Tipos de Análisis Forense

- **Dispositivos Informáticos** → Identificación y recuperación de información de equipos informáticos.
- **Dispositivos Móviles** → Orientado a smartphones, tables, etc.
- **Memoria** → Se ocupan de la RAM y de discos duros.

- **Redes** → Investigan el tráfico y las comunicaciones de la red.
- **Software y Malware** → Examinan el software y el código malicioso para identificar vulnerabilidades y entender el comportamiento de los ataques.

9.3 Fases

1. **Estudio Inicial** → Identificar y asegurar la escena evitando que sean alteradas.
2. **Identificación de Evidencias** → Realizar inventario exhaustivo de los dispositivos.
3. **Adquisición de Datos** → Implica la extracción y copia de información relevante de los dispositivos.
4. **Preservación de Evidencias** → Evitar el mal uso o mala manipulación de “pruebas”.
5. **Análisis de Evidencias** → Análisis de metadatos, registros de actividad para identificar patrones.
6. **Recuperación de Datos** → Puede que sea necesario recuperar datos eliminados o dañados.
7. **Análisis de Malware** → Realiza un análisis detallado para entender su funcionamiento y efectos.
8. **Documentación y Reporte** → Todo el proceso debe ser documentado.
9. **Cumplimiento Legal y Ético** → El análisis forense debe cumplir todas las leyes y regulaciones aplicables.